

PROJECT REPORT OF CO-OP Project at Industry (Module-2)

ON

SHADOW AI

submitted in partial fulfilment of the requirements for the award of degree of

BACHELOR OF ENGINEERING

In

COMPUTER SCIENCE AND ENGINEERING

Submitted by:

Mayank Dhankhar 2210994811

Arjun 2210990154

Trish Palia 2210992467

Taranpreet Kaur 2210990908

Supervised By:

Ashish Kumar

Associate Professor-Head Operations

Department of CSE (Zeta Cluster)

**Chitkara University Institute of Engineering
and Technology**



DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING

**CHITKARA UNIVERSITY INSTITUTE OF ENGINEERING AND TECHNOLOGY
CHITKARA UNIVERSITY, PUNJAB, INDIA**

DECLARATION

I hereby certify that the work which is being presented in the project report entitled **SHADOW AI** in partial fulfilment of requirement for the award of the degree of Bachelor of Engineering (Computer Science and Engineering) submitted in the department of Computer Science and Engineering at Chitkara University Institute of Engineering and Technology, Chitkara University, Punjab, India, is an authentic record of my own work carried out under the supervision of **Ashish Kumar**. The matter presented in this project report has not been submitted in any other university/institute for the award of any degree.

Mayank Dhankhar 2210994811

Arjun 2210990154

Place: Rajpura

Trish Palia 2210992467

Date: 04-30-2026

Taranpreet Kaur 2210990908

This is to certify that the above statement made by the candidate is correct to the best of my knowledge and belief.

Ashish Kumar

Associate Professor-Head Operations

Department of Computer Science and Engineering

Chitkara University Institute of Engineering and Technology,

Chitkara University, Punjab, India

ACKNOWLEDGEMENT

We would like to express our sincere gratitude to our project supervisor, Ashish Kumar, Department of Computer Science and Engineering, Chitkara University, Punjab, for his invaluable guidance, continuous encouragement, and insightful feedback throughout the development of this project.

We are thankful to the Department of Computer Science and Engineering, Chitkara University, for providing us with the resources and environment needed to carry out this work as part of the COOP Industry Project (Module-1).

Team Members:

Mayank Dhankhar 2210994811

Arjun 2210990154

Trish Palia 2210992467

Taranpreet Kaur 2210990908

Abstract

Shadow AI—the unauthorized use of AI tools by employees without organizational oversight—is a rapidly escalating enterprise risk. Driven by productivity pressures, absent approved alternatives, and implicit leadership tolerance, it creates critical threats: data breaches averaging \$4.63 million (\$670,000 above standard incidents), systematic violations of GDPR, HIPAA, and PCI DSS, and irreversible intellectual property loss. With 65% of workers already using unsanctioned AI and only 9–12% of organizations operating functional governance frameworks, the preparedness gap is severe. Effective mitigation requires a "Consolidate, Don't Confiscate" governance model—providing enterprise-approved tools, applying a five-pillar framework (Accept, Enable, Assess, Restrict, Eliminate), deploying layered technical guardrails, and investing in sustained employee education.

Keywords: *Shadow AI, AI Governance, Data Security, Enterprise AI, Compliance, Intellectual Property, GDPR, HIPAA, EU AI Act*

Table of Contents

Page No.	Content
2	Abstract
4	Introduction
6	Security and Privacy Threats
8	Organizational Awareness and Policy Preparedness
10	Governance Strategies and Preventive Measures
12	Future Outlook and Developing Challenges
14	Key Results and Findings
15	Conclusion
16	References

1. Introduction

1.1 What is Shadow AI?

Shadow AI refers to the unauthorized use of artificial intelligence tools by employees without the consent, oversight, or participation of an organization's IT or security department. It typically arises when workers independently adopt AI systems—chatbots, code assistants, large language models—to accelerate document production, meeting summaries, or data analysis, bypassing formal approval processes.

While Shadow AI falls under the broader Shadow IT umbrella, it introduces distinctly heightened risks. Shadow IT generally concerns unauthorized software or hardware; Shadow AI additionally risks data leakage, IP exposure, and violations of AI-specific regulations such as the EU AI Act. It also introduces model hallucinations, output bias, and the fundamentally unpredictable behavior of generative models—challenges that conventional IT governance frameworks are not equipped to address.

1.2 Scope & Prevalence — The Scale of the Problem

Unauthorized AI adoption is both rampant and growing. The statistics paint a striking picture:

65% Workers using unauthorized AI	49% Adopted AI without employer approval	80% US office workers use AI at work	22% Rely only on company tools	52% Conceal AI use from employer
--	---	---	---	---

Shadow AI usage varies significantly by industry and department. Retail/E-commerce leads at 72%, followed by Manufacturing (67%), Financial Services (66%), and Healthcare (57%). Departmentally, Operations (72%) and IT/Technology (68%) show the highest rates. Generationally, Gen Z employees (aged 18–24) are 35% more likely to use personal-only AI tools compared to 14% in other age groups; 30% of this youngest cohort cite leadership resistance as the primary barrier to formal AI adoption.

Table 1: Shadow AI Adoption by Industry

Industry	Shadow AI Usage Rate
Retail / E-commerce	72%
Manufacturing	67%
Financial Services	66%
Technology / SaaS	64%

Healthcare	57%
------------	-----

1.3 Major Driving Forces

Five interrelated factors drive Shadow AI adoption across organizations:

- **Productivity Pressure:** 97% of employees believe AI improves their performance; one-third save approximately six hours per week. Strikingly, 60% believe the security risk is justified by the efficiency gain.
- **Gaps in Official Provisions:** 63% use AI when no employer-approved option exists; 32% find official tools inadequate; 28% cite excessively slow IT approval processes.
- **Leadership Tolerance:** 69% of C-suite executives and 66% of senior VPs prioritize speed over privacy, implicitly condoning unsanctioned usage. An additional 21% of employees believe management turns a blind eye as long as work is completed.
- **Ease of Access:** 58% use free, web-based tools that require no coding and bypass conventional IT monitoring through standard browser activity.
- **Psychological Factors:** Employees use AI to manage productivity pressure and demonstrate relevance in a workplace where AI is perceived as a job-replacement threat.

1.4 Risky Data-Sharing Patterns

The scale of risky data-sharing practices is significant. Employees using unauthorized tools frequently upload highly sensitive content:

- 33% have shared enterprise research or datasets with public AI tools
- 27% have shared confidential employee data such as salary or performance information
- 23% have entered company financial data into consumer AI platforms
- 51% have connected AI tools directly to company systems without IT awareness or consent

2. Security and Privacy Threats

2.1 Data Breach Mechanisms and Financial Costs

Shadow AI has become a major contributor to enterprise data breaches. According to IBM's 2025 Cost of a Data Breach Report, Shadow AI now accounts for 20% of all data breaches—more than any single breach category involving approved AI systems. The financial premium is substantial: Shadow AI breaches average \$4.63 million, which is \$670,000 higher than the average incident cost across all breach types.

Several factors compound this cost premium. Shadow AI breaches are largely invisible to monitoring systems—taking 26.2% longer to detect and 20.2% longer to contain—averaging 291 days total. Furthermore, 65% of Shadow AI breaches involve customer Personally Identifiable Information (PII), a far higher proportion than the global breach average.

Table 2: Average Data Breach Cost by Industry (Shadow AI Incidents)

Industry	Avg. Breach Cost	Key Vulnerability
Healthcare	\$7.42M	PHI exposure through unsanctioned AI; low visibility
Financial Services	\$5.56M	Frequent sharing of private financial data
Technology	\$4.79M	Proprietary IP processed by external AI models
Global Average	\$4.63M	20% of all breaches; +\$670K cost premium

2.2 Compliance Violations Across Regulatory Frameworks

Unsanctioned AI tools systematically violate multiple regulatory frameworks. Employees feeding sensitive data into public AI systems typically do so without lawful basis, appropriate safeguards, or accountability mechanisms:

- **GDPR Violations:** Art. 6 (no lawful basis), Art. 5(1)(b) purpose limitation, Art. 32 (no secure processing), Ch. V (unauthorized international transfers)
- **HIPAA Violations:** Unauthorized handling of Protected Health Information (PHI), violated audit controls, no Business Associate Agreements (BAAs) with AI vendors
- **PCI DSS Violations:** Payment data via unsecured AI integrations, failed data segmentation and access control requirements
- **SOX / CCPA:** Financial data integrity failures under SOX; consumer privacy violations under CCPA

Governance gaps severely compound compliance risk: 83% of organizations lack basic technical controls to contain data exposure through AI tools, and only one-fifth can actually block unauthorized data uploads to AI platforms.

2.3 Intellectual Property Contamination

Shadow AI presents a uniquely irreversible threat to intellectual property. Unlike traditional data theft, when proprietary information is fed into a public AI model, it may be absorbed into the model's training data or retained on third-party servers permanently—beyond the organization's reach. Three main vectors of IP loss include:

- **Source Code Exposure:** Developers posting proprietary code for debugging or optimization leave it on external servers the company does not control.
- **Strategic Document Leakage:** Submitting confidential strategy documents, research reports, or financial projections to AI tools exports trade secrets and competitive intelligence.
- **Permanent Training Contamination:** Many free or low-tier AI tools train future model versions on user-provided data, making any disclosure non-retrievable.

Case Study — Samsung ChatGPT Incident (2023): Engineers uploaded internal semiconductor source code and meeting notes to OpenAI's servers for debugging assistance. The data landed on third-party

servers permanently. Samsung responded by banning ChatGPT internally and accelerating an enterprise-secured AI platform. This canonical case illustrates that IP loss is not the product of malicious intent but of productivity-seeking with catastrophic unintended consequences.

2.4 Novel Technical Vulnerabilities

Shadow AI also introduces emerging attack vectors that existing security controls are not designed to handle:

- **Prompt Injection Attacks:** Attackers embed instructions in AI inputs that override safety constraints, extract sensitive data, or trigger unintended actions.
- **AI Supply Chain Poisoning:** Unsanctioned models may have been trained on tainted or maliciously poisoned data, producing biased, incomplete, or adversarially crafted outputs.
- **Expanded Attack Surface:** Shadow AI tools frequently use unsecured APIs, uncontrolled integrations, or run on personal devices. The average enterprise unknowingly hosts ~1,200 unofficial applications, many with risky OAuth access.
- **Governance Failure at Scale:** 97% of organizations that experienced AI-related data breaches lacked appropriate AI access controls—a systemic failure underpinning all other vulnerabilities.

3. Organizational Awareness and Policy Preparedness

3.1 Current Awareness Levels

Organizational awareness of Shadow AI risks exhibits a troubling paradox: widespread underestimation at leadership level despite high ground-level exposure. While 49% of workers use AI tools without employer approval and 86% use AI for work at least weekly, 69% of C-suite executives and 66% of senior VPs prioritize speed over security—effectively normalizing the behavior.

Three key dimensions define the awareness deficit:

- **Visibility Deficits:** Shadow AI operates invisibly through browser extensions, plugins, and AI-enabled SaaS applications that bypass traditional monitoring.
- **Psychological Barriers:** Identity anxiety among high-skill employees inhibits disclosure of AI use—52% actively conceal their AI usage.
- **Strategic Disconnect:** 87% of leaders expect AI agents to transform governance within a year, yet most organizations lack the structural foundations to support this transition.

3.2 Policy Preparedness and Governance Maturity

Policy preparedness varies significantly, with the majority of organizations operating in a reactive rather than proactive governance posture. Key statistics reveal the depth of unpreparedness:

- Only 14% of boards routinely discuss AI risk
- Only 13% of S&P 500 companies have directors with AI expertise
- Only 9–12% of organizations operate functional AI governance frameworks
- 86% cannot monitor AI data flows; 83% lack even basic technical controls

The AI Governance Maturity Matrix (UC Berkeley, 2025) maps governance transition across five dimensions—Strategy, People, Processes, Ethics, and Culture—from Reactive (awareness only after failure) to Transformative (AI governance embedded in all decisions). Most organizations remain firmly in the Reactive stage.

Table 3: Regulatory Evidence Requirements (Compliance Gaps from Shadow AI)

Regulatory Framework	AI-Specific Evidence Gap
PCI DSS Requirement 10	Logging of AI tool access to cardholder data environments
HIPAA (45 CFR §164.312(b))	Tracking PHI access through AI prompts and interactions
SOC 2 CC7.2	Monitoring AI system components and agents for anomalous behavior
GDPR Article 28	Documented data processing agreements for AI tools handling personal data

3.3 Critical Governance Gaps

- **Operationalization Deficit:** Half of executives cite translating Responsible AI principles into scalable, repeatable operational processes as their greatest challenge.
- **IP Protection Absence:** Organizations lack policies preventing proprietary information from being absorbed into commercial AI training pipelines.
- **Agentic AI Blind Spots:** 80% of organizations have already encountered risky AI agent behaviors, yet most have no controls covering unsanctioned plugins, agentic workflows, or autonomous AI integrations.
- **Visibility Infrastructure Gap:** 86% cannot monitor AI data flows; 83% lack even basic technical controls to limit data exposure.

4. Governance Strategies and Preventive Measures

4.1 The "Consolidate, Don't Confiscate" Paradigm

Blanket bans are counterproductive—they drive usage underground, demoralize employees, and increase risk without reducing it. The proven alternative is to channel behavior rather than prohibit it. Organizations must:

1. Designate one enterprise-scale AI platform (e.g., Microsoft Copilot) capable of meeting 80%+ of employee needs
2. Make the official tool more convenient than consumer alternatives through better UX and accessibility
3. Create a lightweight intake framework for evaluating external AI tools based on problem solved, data accessed, retention policy, and ROI

4. Deploy telemetry to measure adoption through weekly active users, prompts submitted, and estimated time saved

4.2 Five-Pillar Governance Framework

A harmonized governance framework must both permit beneficial AI use and limit dangerous practices. The following five pillars provide a structured, actionable model:

Table 4: Five-Pillar AI Governance Framework

Pillar	Purpose	Implementation
Accept	Encourage productive AI usage	Allow AI for brainstorming, drafting, and rewriting without sensitive data input
Enable	Provide sanctioned enterprise tools	Deploy enterprise-approved platforms with appropriate data protection controls
Assess	Evaluate new AI tools systematically	Implement a rapid, lightweight intake and review process for tool evaluation
Restrict	Prevent data exposure via personal accounts	Clearly prohibit use of personal AI for processing sensitive or confidential corporate data
Eliminate	Address data retention risks	Consolidate AI to enterprise tools to prevent data remaining in personal accounts post-offboarding

4.3 Technical Controls and Guardrails

Effective governance demands layered technical controls deployed across the entire AI lifecycle:

- **Data Safety:** Enforce data integrity through input validation, access controls, and continuous quality monitoring to ensure AI systems are trained and operated only on trusted data.
- **Model Guardrails:** Establish pre-deployment and post-deployment testing protocols for model drift, bias identification, and performance degradation.
- **Application & Output Guardrails:** Validate AI outputs—especially in decision-support contexts—by establishing approval thresholds, escalation protocols, and human-in-the-loop requirements.
- **Infrastructure Guardrails:** Secure AI workload environments with access restrictions, comprehensive logging, and integration with existing SIEM and incident response systems.
- **Continuous Monitoring:** Deploy AI endpoint logging, behavioral anomaly detection, and vendor risk management software to surface new generative AI tool adoption in real time.

4.4 Employee Education and Cultural Transformation

The human factor is simultaneously the most exploited vulnerability and the most powerful control. Change programs fail at rates up to 70% when cultural transformation is neglected. Comprehensive education must include:

- Risk awareness: data exposure consequences, regulatory penalties, and IP loss implications

- Role-specific guidance: practical do/don't instructions for each department's AI workflow
- Responsible AI ethics training: bias awareness, data stewardship, and accountability
- Genuine change management with transparent communication, employee participation, and leadership modeling

5. Future Outlook and Developing Challenges

5.1 Evolving AI Capabilities and Risk Vectors

By 2026, AI transitions from experimental to operationally essential, making unsanctioned use simultaneously more tempting and more consequential. Agentic AI—executing multi-step autonomous workflows from a single human prompt—operates outside standard API controls and creates compound, opaque risks with ambiguous liability chains. Multimodal capabilities (text, image, audio) expand the sensitive data exposure surface. Healthcare organizations, for example, already face risk exposure when using cloud-based AI models to analyze medical imaging.

5.2 The Regulatory Horizon (2026 and Beyond)

Table 5: Global Regulatory Landscape for Shadow AI (2026)

Region	Key Development (2026)	Shadow AI Implication
European Union	EU AI Act core obligations effective August 2026	All AI systems must be risk-categorized; undiscovered Shadow AI creates major compliance gaps
United States	Proliferation of state-level AI regulations on transparency and employment	Unsanctioned AI in HR decisions (hiring, promotion) creates non-compliance exposure
China	Mandatory filing and registration of large language models	Multinationals must inventory all AI usage, including Shadow tools in Chinese operations
Latin America	Peru's framework and expected laws in Brazil and Chile	Shadow AI bypassing data governance directly violates privacy fundamentals

5.3 Technological Detection and Emerging Countermeasures

AI Security Posture Management (AI-SPM) tools are emerging as a critical capability—providing complete pipeline visibility, identifying malicious configurations, and delivering audit records, request logs, and policy violation reports required for governance and incident response.

A layered detection architecture combining Cloud Access Security Brokers (CASB), Data Loss Prevention (DLP), and behavioral analytics is emerging as the standard—though only 17% of organizations currently

have the capability to prevent unauthorized data uploads to AI platforms. The paradigm shift toward Data-First Security treats data itself, rather than infrastructure, as the core protected asset—implemented through Data Security Posture Management (DSPM) technologies.

5.4 Insurance, Risk Economics, and Long-Term Imperatives

Insurers are reacting to unquantifiable AI risks by introducing broad liability exclusions covering any use, deployment, or development of AI systems. Organizations must demonstrate observable, enforceable, and auditable AI behavioral controls with comprehensive logging to obtain meaningful coverage. Three long-term strategic imperatives emerge:

- **Adaptive Governance:** Architecting governance systems that evolve dynamically with AI capabilities rather than relying on static policies
- **Auditor Capability Development:** Investing in in-house AI audit competencies and engaging external AI audit specialists to address the critical shortage of skilled AI auditors
- **Responsible AI Culture:** Reinforcing technical controls through sustained cultural transformation where AI experimentation is channeled through legitimate, governed pathways

6. Key Results and Findings

The research synthesis across industry reports, academic papers, and statistical surveys (2023–2026) establishes six core findings:

R1	Shadow AI is ubiquitous: 65% of workers use unauthorized tools; only 22% rely exclusively on company-approved AI.
R2	Financial impact is massive: Shadow AI breaches average \$4.63M — \$670K above standard breach costs, accounting for 20% of all incidents.
R3	Detection takes far too long: Shadow AI breaches average 291 days to identify and contain — 26% longer than standard breaches.
R4	Compliance failures are systemic: 83% lack basic controls; 86% have zero visibility into what employees share with AI tools.
R5	Leadership is part of the problem: 69% of C-suite members prioritize speed over privacy, implicitly enabling Shadow AI.
R6	'Consolidate, Don't Confiscate' works: Organizations providing enterprise-grade AI reduce shadow usage and improve governance posture.

7. Conclusion

Shadow AI represents one of the most consequential and least-governed risks in the modern enterprise. Its prevalence—65% of employees using unsanctioned AI tools, 30% uploading confidential data to public

platforms—is not an anomaly but a structural response to organizational failure: the failure to provide adequate approved alternatives, to close the gap between leadership AI strategy and employee AI reality, and to establish governance infrastructures that keep pace with the velocity of AI innovation.

The threat profile is severe and multi-dimensional. Data breaches attributable to Shadow AI carry a \$670,000 cost premium above standard incidents. Systematic compliance exposure spans GDPR, HIPAA, PCI DSS, and the imminent EU AI Act. Intellectual property contamination—as illustrated by the Samsung ChatGPT incident—can be permanent and non-recoverable. Yet only 9–12% of organizations operate functional AI governance frameworks, and 83% lack even basic technical controls.

The evidence clearly establishes that prohibition is not the solution. Blanket bans suppress visibility without reducing risk, driving Shadow AI further into ungoverned territory. The path forward is the "Consolidate, Don't Confiscate" paradigm: designating and optimizing enterprise-approved AI tools, applying the five-pillar governance framework (Accept, Enable, Assess, Restrict, Eliminate), deploying layered technical guardrails from data validation to AI-SPM monitoring, and embedding responsible AI education into organizational culture at every level.

As regulatory pressure intensifies globally through 2026—with the EU AI Act, expanding US state regulations, and China's registration mandates—Shadow AI will shift from a governance gap to a compliance liability. Organizations that proactively build adaptive, auditable, and employee-centric AI governance frameworks will not only mitigate this risk but will be positioned to convert responsible AI governance into a competitive advantage.

8. References

The following references were consulted in the preparation of this report:

- [1] Palo Alto Networks, "What Is Shadow AI? How It Happens and What to Do About It," Cyberpedia, 2025.
- [2] Bennett Jones, "Hiding in the Shadows: The Perils of Shadow AI on Your Organization," 2025.
- [3] ISACA, "The Rise of Shadow AI: Auditing Unauthorized AI Tools in the Enterprise," 2025.
- [4] Cyber Advisors, "From Shadow IT to Shadow AI: Why History is Repeating Itself," 2025.
- [5] Varonis, "Hidden Risks of Shadow AI," 2025.
- [6] Sweep, "The Big AI at Work Study 2025," 2025.
- [7] CIO, "Roughly half of employees are using unsanctioned AI tools," 2025.
- [8] IBM, "Is rising AI adoption creating shadow AI risks?" IBM Think, 2025.
- [9] IDC, "Shadow AI: How stealth productivity is strangling enterprise AI adoption," 2025.
- [10] Kiteworks, "IBM 2025: 97% AI Breaches Lack Controls Shadow AI," 2025.
- [11] IBM, "Hidden risk of shadow data and shadow AI — higher costs," IBM Think, 2025.
- [12] CyberPeace, "Shadow AI — The Hidden Risk Undermining Organisational Security," 2025.
- [13] F5, "Shadow AI: The Silent Security Risk Lurking in Your Enterprise," 2025.
- [14] Netwrix, "12 Critical Shadow AI Security Risks Your Organization Needs to Address," 2025.
- [15] PwC, "2025 Responsible AI Survey: From Policy to Practice," 2025.

- [16] UC Berkeley, "AI Governance Maturity Matrix," California Management Review, 2025.
- [17] K2 Integrity, "Shadow AI Governance: How To Manage Hidden GenAI Risks," 2026.
- [18] Ivanti, "AI Governance Framework: Responsible AI Guardrails," 2025.
- [19] Dentons, "2026 Global AI Trends: Six Key Developments Shaping the Next Phase," 2026.
- [20] SurePath AI, "Insurance won't cover AI risks. Visibility will," 2026.
- [21] UpGuard, "The Shadow AI Data Leak Problem No One's Talking About," 2025.
- [22] Vanta, "Shadow AI: What it means and how to manage it," 2025.
- [23] Wiz, "What is Shadow AI? Why It's a Threat and How to Embrace It," 2025.
- [24] Cloud Security Alliance, "Addressing Employee Resistance to AI Adoption," 2025.
- [25] N. Landers, "Shadow AI: The Hidden Risk In Plain Sight," LinkedIn Pulse, 2025.
- [26] Zendata, "AI Governance Maturity Models 101," 2025.
- [27] Cornerstone, "Shadow AI: the enterprise risk hiding in plain sight," 2025.